Module 5 Compliance & Supply Chain

EXERCISE 5.1 · COMPLETE WALKTHROUGH

Compliance Obligation Register & Comprehensive Self-Audit

Docker range walkthrough — HTML Compliance Management Portal + Virtual Evidence Repository on a simulated OT plant

DURATION
180 minutes · 4 phases

STANDARDS MAPPED
IEC 62443-2-1 (Compliance Assessment), IEC 62443-2-4, IEC 62443-3-3

REGULATORY SOURCES
First Schedule records · IT Act 2000 s.70 · CERT-In Directions 28.04.2022

CORE FOCUS
Obligation Register · Evidence Linking · Gap Analysis · Corrective Action

DELIVERY PLATFORM
Docker Compose · 9 containers · segmented IT / OT networks

DOCUMENT
Instructor & trainee walkthrough · v1.0 · November 2026

Contents

1. Objective
2. Beneficiary
3. Narrative — the Plant Unit 2 scenario
4. Lab environment & setup
5. Phase 1 — Build the obligation register
6. Phase 2 — Collect and link evidence
7. Phase 3 — Automated gap analysis
8. Phase 4 — Corrective action, remediation, verification
9. Consolidated findings register
10. Deliverables & assessment rubric
11. Debrief & discussion
12. Troubleshooting

Appendix A — Command reference

Appendix B — Rule engine reference

1. Objective

Aim. To make trainees capable of running a complete, evidence-backed compliance self-audit of an operational technology (OT) environment — from interpreting regulatory obligations, through collecting and hashing technical evidence, to raising and verifying corrective actions — using the same *Find → Validate → Measure → Fix → Verify* discipline applied in an offensive assessment.

Learning objectives

1. **Build and manage a comprehensive compliance obligation register** mapping regulatory clauses (First Schedule, National Acts, IEC 62443 baselines) to technical controls.
2. **Link technical configuration artifacts** from the virtual environment — firewall backups, IAM logs, encryption settings, compensating-control rules — directly to audit evidence requirements.
3. **Execute automated compliance gap-analysis scripts** and formulate actionable corrective action plans.

Measurable performance outcomes

By the end of the 180-minute exercise each trainee will have demonstrably:

Outcome	Observable evidence	Target
Complete register	All obligations from the regulatory extract registered with testable requirement, control reference, owner and review frequency	13 / 13
Defensible evidence	Every evidence link carries a SHA-256 hash and an assessment note stating what the artifact proves or does not prove	100 % of links
Validated findings	Automated findings independently confirmed against raw artifacts; additional manual findings identified	≥ 3 validated, ≥ 2 manual
Rule authoring	A new detection rule added to `rules.yaml` that fires on the live evidence	1 rule
Actionable CAP	Critical and High items have owner, due date and root-cause-driven action	All C/H items
Verified closure	Remediated items closed by a passing re-test, not by self-declaration	Both Criticals + 2

Competencies developed

GOVERNANCE
Translating legal and standards text into testable, owned obligations; understanding why an unregistered obligation is invisible to governance.

EVIDENCE HANDLING
Hash-at-collection, immutable snapshots and chain-of-custody logging — skills directly transferable to digital forensics.

TECHNICAL AUDIT
Reading firewall rulesets, IAM exports, crypto configuration and compensating-control registers as an auditor rather than an operator.

RISK & REMEDIATION
Root-cause analysis, severity-based due dates, justified risk acceptance and closure by re-test.

2. Beneficiary

Primary beneficiaries — trainees

Audience	What they gain from this exercise
Law-enforcement cyber officers & investigators	How a regulated OT operator should evidence compliance; what a 6-hour CERT-In reporting obligation means operationally; how hashed evidence and custody logs make audit artifacts admissible-grade. Directly useful when investigating incidents at critical-infrastructure sites.
CISOs, OT security officers & plant engineers	A working template for their own obligation register and quarterly self-audit; insight into how commissioning shortcuts (temporary rules, wildcards, shared accounts) silently become compliance failures.
Internal & external IS auditors	Practice in validating automated findings, finding what scripts miss, and refusing to accept policy claims without operating evidence (the s.70 audit-calendar gap).
SOC analysts & threat hunters	Recognising that an audit artifact (`auth.log`) can contain a live security signal — the brute force from Corporate IT — and escalating accordingly.
Red-team & VAPT practitioners	Mapping technical findings to regulatory obligations so that penetration-test reports drive measurable remediation.

Organisational beneficiaries

- **Critical-infrastructure asset owners** gain staff who can run a defensible self-audit before the external auditor or regulator arrives.
- **Regulators and nodal agencies** benefit from operators whose compliance claims are backed by traceable, hashed technical evidence.
- **Training institutions** receive a reusable, resettable range (`./lab.sh reset`) with an answer key and rubric for consistent assessment across batches.

Prerequisites

KNOWLEDGE

Purdue model / zones and conduits, basic firewall rule reading, JSON, familiarity with IEC 62443 structure (Modules 1–4).

PLATFORM

Docker Engine 24+ with Compose v2, ~1 GB disk, ports 8080 and 8081 free, a modern browser. Linux, macOS or Windows (Docker Desktop / WSL2).

3. Narrative — the Plant Unit 2 scenario

It is Friday, 6 November 2026. You have just been appointed **Compliance Lead for Plant Unit 2**, a process plant whose DCS/SCADA has been notified as a **Protected System under Section 70 of the IT Act, 2000**. Your predecessor left three weeks ago. The handover consisted of a half-finished obligation register in the Compliance Management Portal and a note: *"Self-audit overdue. External audit due 20 November."*

The external audit is fourteen days away and the auditor has not yet been engaged. The CISO wants a full, evidence-backed self-audit on her desk by the end of today so that corrective actions can start on Monday.

> *"I don't want opinions. For every obligation, show me the artifact, the hash, the verdict and who is fixing it." — CISO, Plant Unit 2*

Plant Unit 2 was commissioned eighteen months ago by an external integrator. Commissioning was rushed. During Factory and Site Acceptance Testing, engineers needed to reach the PLCs from corporate laptops, so a *temporary* firewall rule, **CHG-1184**, was added. Shift operators share one HMI login because it was "easier for handovers". The integrator asked for persistent remote access to meet its support SLA. Someone troubleshooting a Modbus timeout added a wildcard to the gateway's write list. None of these decisions was malicious, and none was ever reversed.

Earlier this year the plant accepted that controller **PLC-01** could not be patched and approved a **compensating control (CC-001)**: Modbus writes would be accepted only from the engineering workstation. CC-001 expired on 30 June 2026. Nobody noticed. Nor did anyone notice that the wildcard had quietly defeated it months earlier.

The organisation's Incident Response Plan was last revised in 2024. It still says incidents are reported to CERT-In within 24 hours — not the six hours the 2022 Directions require. The SIEM keeps 90 days of logs, not 180. The historian still accepts TLS 1.0.

The plant is segmented into an **IT zone** and an **OT zone**. Your auditor workstation is the only system permitted to bridge both. Each OT asset exposes a read-only configuration export for audit purposes. Your job today:

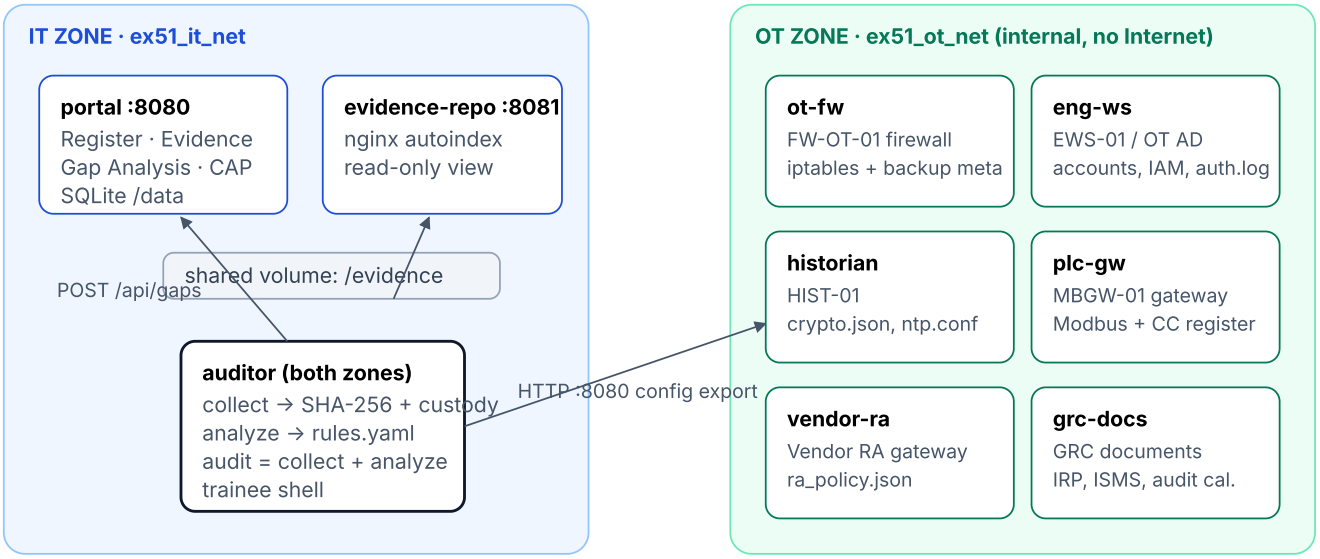
1. Fix the register so that it reflects every obligation the plant is actually bound by.
2. Collect configuration evidence from every asset, hash it, and record chain of custody.
3. Run the automated gap analysis, validate it, and find what it misses.
4. Build a corrective action plan, have asset owners remediate the most dangerous gaps, and **prove** by re-test that they are fixed.

Somewhere in the evidence you will also find something that is not merely a compliance gap — it is a security event happening on your network. A good auditor notices it.

> **Facilitator note.** Keep the narrative alive throughout: refer to the CISO's demand when trainees link evidence without notes, and to the 20 November audit when they set CAP due dates.

4. Lab environment & setup

Architecture



Container	Network	Role in the exercise
`portal`	IT	Compliance Management Portal: Obligation Register, Evidence, Gap Analysis, Corrective Actions, CSV exports. Port 8080.
`evidence-repo`	IT	Read-only browsable index of `/evidence`: snapshots, manifests, reports and `custody.log`. Port 8081.
`auditor`	IT + OT	Trainee workstation with `collect`, `analyze`, `audit`, plus curl, jq and nano.
`ot-fw · eng-ws · historian · plc-gw · vendor-ra · grc-docs`	OT (internal)	Simulated assets serving their configuration from `range/assets/<asset>/`. Editing these files simulates the asset owner applying a change.

Package layout

```
tree
```

```
ex51-compliance-lab/
├── docker-compose.yml        lab.sh            README.md
├── portal/                   Flask portal, templates, seed/obligations.json
├── auditor/                  collect.py  analyze.py  rules.yaml  assets.yaml
├── seed/assets/              pristine vulnerable configs (copied to range/assets on first up)
├── handouts/regulatory_extract.md
└── instructor/               ANSWER_KEY.md  solve.sh
```

Bring the range up

1 Unzip and start

```
host
$ unzip ex51-compliance-lab.zip && cd ex51-compliance-lab
$ ./lab.sh up
[*] Range assets seeded from seed/assets
...
  Portal:              http://localhost:8080
  Evidence repository: http://localhost:8081
  Auditor shell:       ./lab.sh shell
```

2 Verify containers and segmentation

```
host / auditor
$ ./lab.sh status           # 9 containers Up
$ ./lab.sh shell
root@auditor:/opt/audit# curl -s http://ot-fw:8080/ | head -3     # OT reachable from auditor
$ docker compose exec portal python -c "import urllib.request;urllib.request.urlopen('http://ot-fw:8080',timeout=3)"
# -> fails: portal is IT-only, cannot reach the OT zone (by design)
```

> **Teaching point:** demonstrate that only the auditor bridges both zones — the same principle as a hardened jump host in an IDMZ.

3 Open the portal

Browse to `http://localhost:8080`. With no evidence collected the dashboard shows 10 obligations, all *Not Assessed*, and a 0 % score.

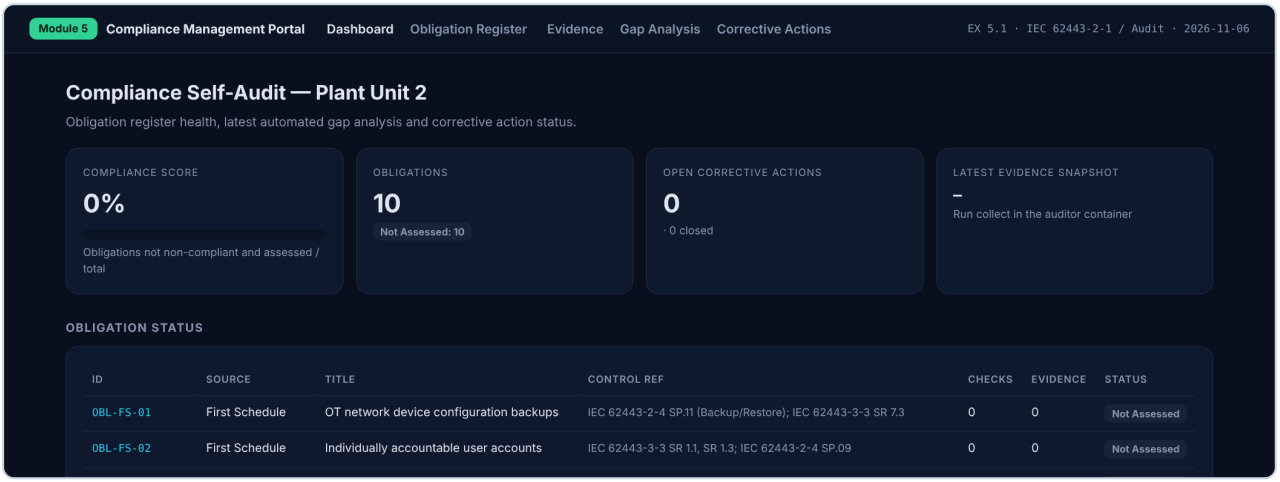


Figure 4.1 — Dashboard before any audit activity

> **Windows without bash:** copy `seed/assets` to `range/assets`, then `docker compose up -d --build` and `docker compose exec auditor audit`.

PHASE 1

Build the obligation register

0:00 — 0:40

Goal: the register must reflect every obligation Plant Unit 2 is bound by, each written as a testable statement and mapped to a technical control.

1 Review the seeded register

Open **Obligation Register**. Ten obligations are seeded across three sources: First Schedule items FS-01..04, National Acts (IT Act s.70, CERT-In log retention) and IEC 62443 baselines (zones & conduits, authentication, authorisation, cryptography).

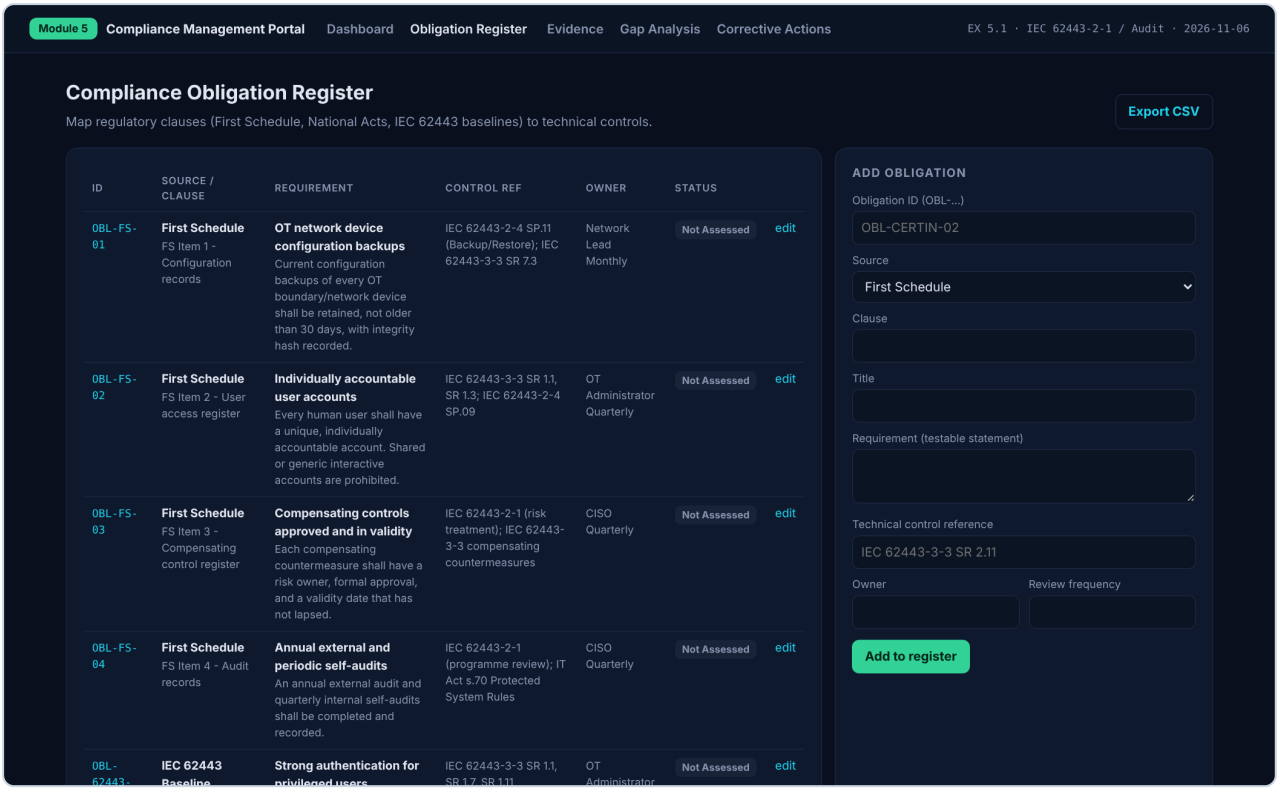


Figure 5.1 — Seeded obligation register (all Not Assessed)

2 Test each requirement for auditability

For each obligation ask: *Could two auditors reach the same verdict from the same evidence?* A requirement needs a subject, a measurable threshold and a control reference. Example: `OBL-FS-01` is testable because it specifies “not older than 30 days” and “integrity hash recorded”.

> **Why it matters:** vague obligations (“backups shall be maintained”) cannot fail an automated check and cannot be closed by re-test.

3 Identify the three missing obligations

Open `handouts/regulatory_extract.md` and compare it line-by-line with the register. Three obligations are absent:

ID	Source	Requirement	Control ref
OBL-CERTIN-02	CERT-In Directions 2022	Synchronise clocks to NIC / NPL NTP (or traceable)	IEC 62443-3-3 SR 2.11
OBL-CERTIN-03	CERT-In Directions 2022	Report cyber incidents to CERT-In within 6 hours of noticing	IEC 62443-2-1 incident mgmt
OBL-24-RA	IEC 62443-2-4 SP.07	Vendor remote access on-demand, approved, MFA, recorded	2-4 SP.07; 3-3 SR 1.13

4 Add them through the portal form

Use the exact IDs from the handout — the automated rules reference them. Fill source, clause, title, testable requirement, control reference, owner and frequency, then **Add to register**.

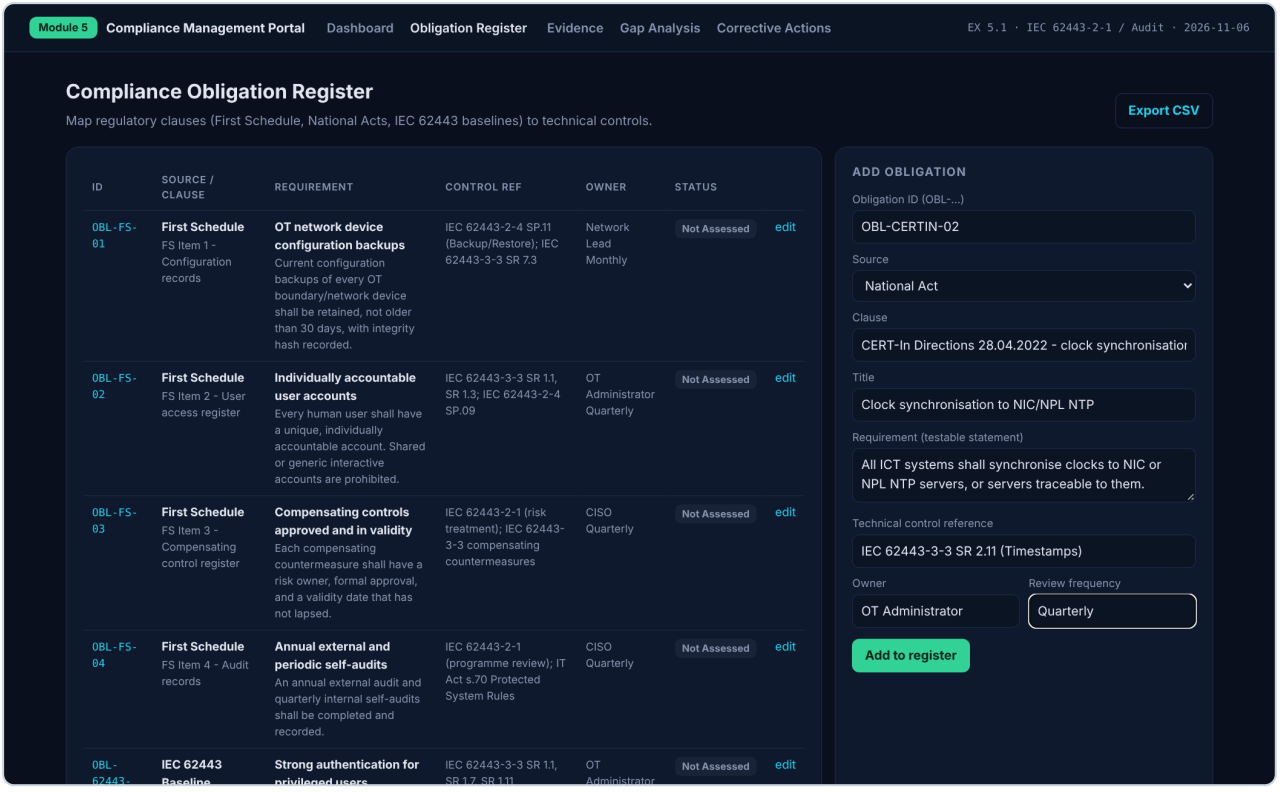


Figure 5.2 — Registering OBL-CERTIN-02 with a testable requirement and SR 2.11 mapping

5 Confirm and export D1

The register now holds 13 obligations; trainee-added entries are tagged *added by trainee*. Click **Export CSV** to produce Deliverable D1.

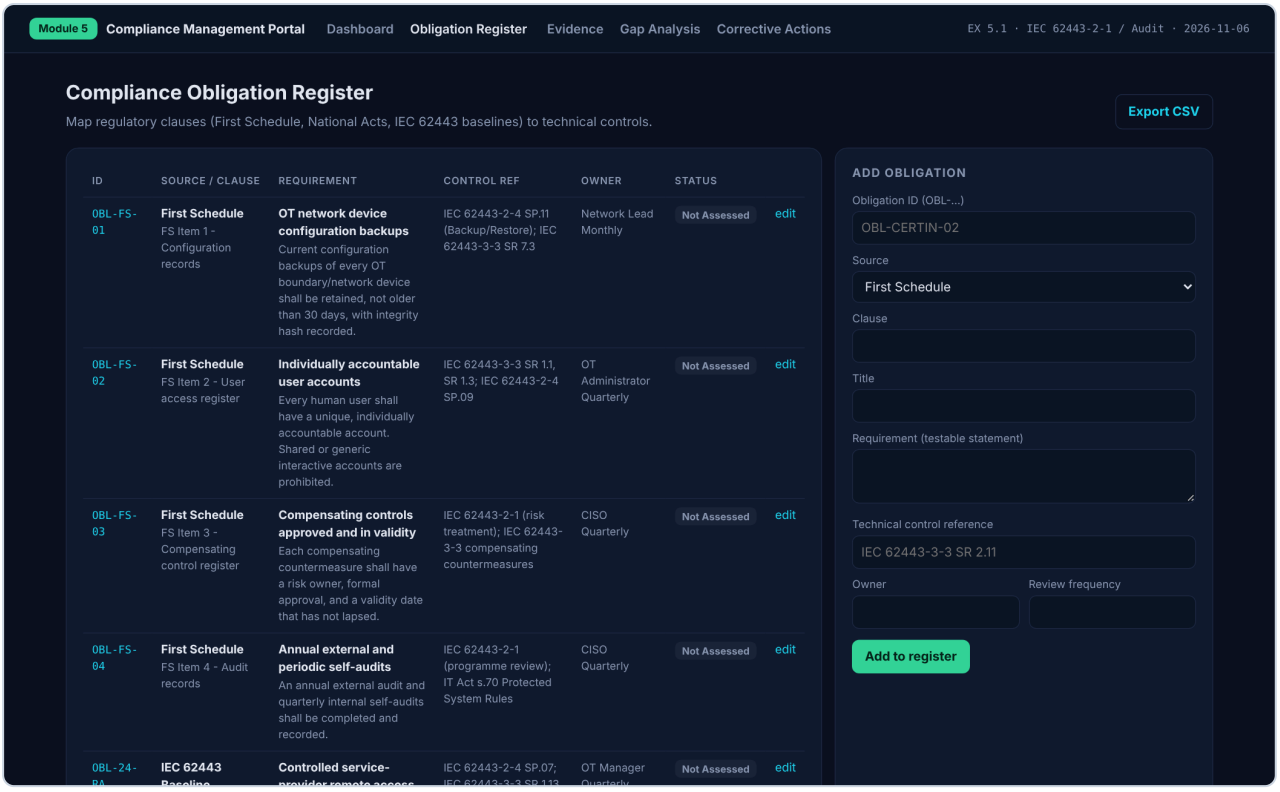


Figure 5.3 — Register after Phase 1

Checkpoint — what happens if Phase 1 is skipped? Running `analyze` before registering the three obligations produces:

```
  [FAIL] CHK-14 Medium   OBL-CERTIN-02     Clock synced to NIC / NPL NTP  <-- UNREGISTERED OBLIGATION
  [FAIL] CHK-17 High     OBL-24-RA         Vendor remote access is on-demand  <-- UNREGISTERED
OBLIGATION
[!] Checks reference obligations missing from the register: OBL-24-RA, OBL-CERTIN-02, OBL-CERTIN-03
```

The dashboard shows a yellow *Register incomplete* banner. Lesson: a failing control mapped to an unregistered obligation has no owner, no review cycle and never reaches management.

PHASE 2

Collect and link evidence

0:40 – 1:30

Goal: obtain a hashed, timestamped snapshot of every asset's configuration and link documentary evidence to obligations that no script can test.

1 Collect evidence from the OT zone

```
root@auditor:/opt/audit# collect

[*] Collection 20261106T094240Z  ->  /evidence/collections/20261106T094240Z
  [+] ot-fw/iptables.rules                 933 B  sha256=df9f3c9e4d7ff7b0...
  [+] ot-fw/backup_meta.json               262 B  sha256=358988a100ce1399...
  [+] eng-ws/accounts.json                1110 B  sha256=540c63c30314cede...
  [+] eng-ws/iam_policy.json               376 B  sha256=8a127dfdd0606715...
  [+] eng-ws/auth.log                     1230 B  sha256=a0ddfa17ffd16939...
  [+] historian/crypto.json                   411 B  sha256=61260bb34f9287af...
  [+] historian/ntp.conf                      152 B  sha256=643968f8a0adac1b...
  [+] plc-gw/compensating_controls.json      837 B  sha256=ec2d8ea9706beb09...
  [+] plc-gw/modbus_gw.json                  315 B  sha256=f81fdcce8933c17c...
  [+] vendor-ra/ra_policy.json                295 B  sha256=6f1cfec1ace7f482...
  [+] grc-docs/incident_response_plan.md      590 B  sha256=500c5fb65c815c83...
  [+] grc-docs/isms_policy.md                 598 B  sha256=abf6f011a25c76d4...
  [+] grc-docs/audit_calendar.json            213 B  sha256=d6747cdd74dfb57a...
[*] 13 artifacts collected, 0 failed. Manifest
sha256=5c453499ede77fa2d809a648fc84aff9abfb165dd89592b8b7c8c0d0e924c124
[*] Chain of custody appended to /evidence/custody.log
```

Each artifact is written twice — to an immutable snapshot `/evidence/collections/<ID>/` and to `/evidence/current/` — with its SHA-256 recorded in `manifest.json`. The manifest itself is hashed into `custody.log`.

2 Inspect chain of custody

```
auditor

root@auditor:/opt/audit# cat /evidence/custody.log
2026-11-06T09:42:40+00:00  COLLECT  20261106T094240Z  collector=trainee  artifacts=13  failed=0
manifest_sha256=…

root@auditor:/opt/audit# sha256sum /evidence/current/ot-fw/iptables.rules
df9f3c9e4d7ff7b0…  /evidence/current/ot-fw/iptables.rules     # matches manifest
```

> **Forensic parallel:** hash-at-acquisition plus an append-only custody record is the same discipline used when imaging a seized disk. Any later change to an artifact is detectable.

3 Read the artifacts as an auditor

Browse `http://localhost:8081/current/` and read every file **before** running any analysis. Record your own observations; you will compare them with the scripts in Phase 3. Key items to notice:

- `ot-fw/iptables.rules` — `:FORWARD ACCEPT` and the commented **TEMP … CHG-1184** rule.
- `eng-ws/auth.log` — who logs in, from where, and how often they fail.
- `plc-gw/modbus_gw.json` vs `compensating_controls.json` — does CC-001 actually operate?
- `grc-docs/incident_response_plan.md` §4 — the reporting window.

4 Link documentary evidence with assessment notes

In **Evidence**, select artifact and obligation, enter your name and an assessment note, then **Link evidence**. Links made in this walkthrough:

Artifact	Obligation	Assessment note (summary)
`grc-docs/isms_policy.md`	`OBL-ITA-70`	s.70 notification and CISO appointment stated; annual empanelled audit only *claimed*.
`grc-docs/audit_calendar.json`	`OBL-FS-04, OBL-ITA-70`	Auditor "TBD", external audit due 2026-11-20; self-audit last 2026-04-15 — overdue.
`eng-ws/auth.log`	`OBL-FS-02`	`operator` used from HMI-01/02/03 — shared account in live use.
`eng-ws/auth.log`	`OBL-62443-AUTH`	6 failed s.iyer logons in 17 s from 10.10.44.7 (Corporate IT); no lockout.

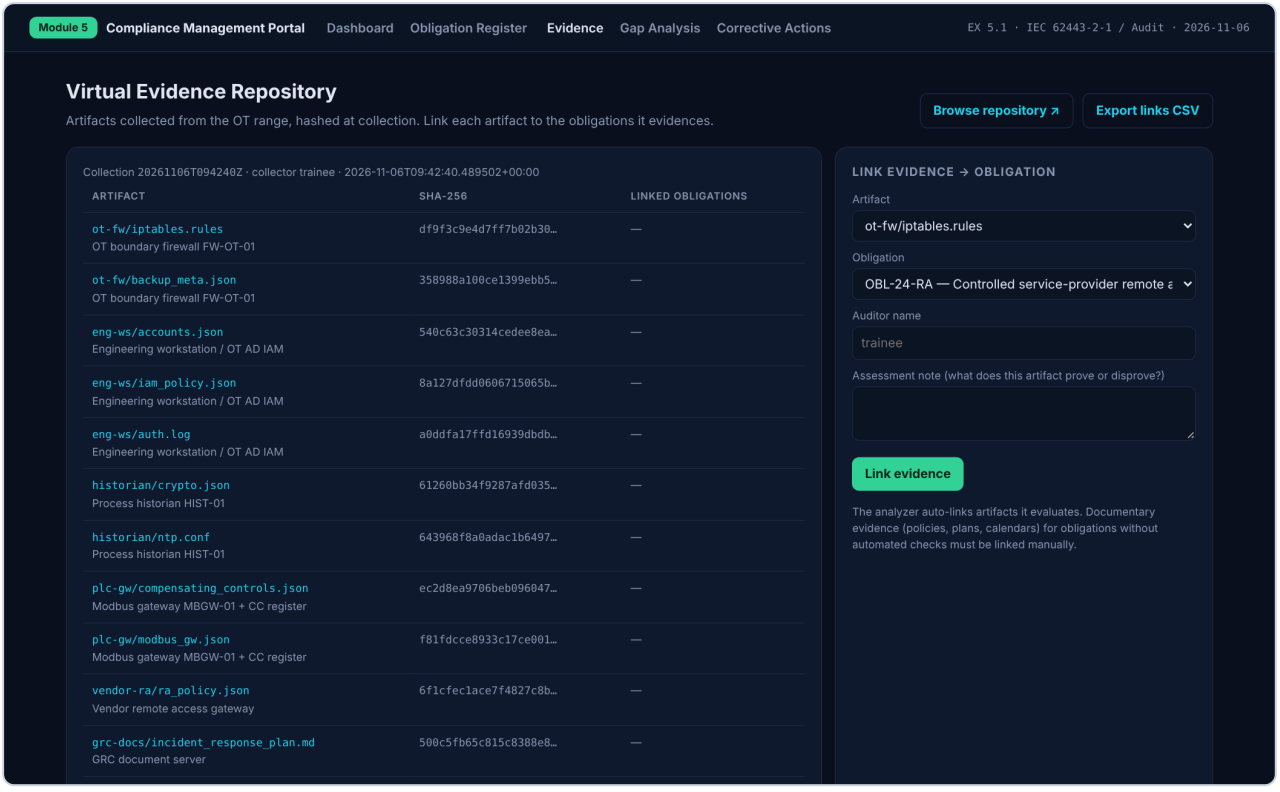


Figure 6.1 — Evidence repository view with manual links and hashes

> **Rule:** a link without a note is not evidence. The note must state what the artifact proves *and what it does not prove*.

5 Export D2

Click **Export links CSV** — this is the evidence-to-requirement traceability matrix (Deliverable D2).

PHASE 3

Automated gap analysis

1:30 – 2:20

Goal: run the rule engine, understand how each verdict is produced, validate it independently, and go beyond it.

1 Run the analyzer

```
root@auditor:/opt/audit# analyze

[*] Gap analysis against collection 20261106T094240Z (audit date 2026-11-06)

  [FAIL] CHK-01 High     OBL-62443-ZC      Conduit default policy is deny
         pattern NOT found: ^:FORWARD DROP
  [FAIL] CHK-02 Critical OBL-62443-ZC      No Corporate IT to Level 1 Modbus flow
         prohibited entries: -A FORWARD -s 10.10.0.0/16 -d 10.40.1.20/32 -p tcp --dport 502 -j
ACCEPT
  [PASS] CHK-03 Medium   OBL-62443-ZC      Denied conduit traffic is logged
  [FAIL] CHK-04 Medium   OBL-FS-01         Firewall config backup is not older than 30 days
         last_backup = 2025-03-14 (602 days old, max 30)
  [FAIL] CHK-05 Low      OBL-FS-01         Backup integrity hash recorded
         integrity_hash_recorded = False (expected True)
  [FAIL] CHK-06 High     OBL-FS-02         No enabled shared interactive accounts
         matching {'shared': True, 'enabled': True}: operator
  [FAIL] CHK-07 High     OBL-62443-AUTH    All enabled privileged accounts have MFA
         matching {'privileged': True, 'mfa': False, 'enabled': True}: s.iyer
  [FAIL] CHK-08 Medium   OBL-62443-AUTH    Password minimum length >= 12
         password.min_length = 8 (minimum 12)
  [FAIL] CHK-09 Medium   OBL-62443-AUTH    Account lockout enabled
         lockout.threshold = 0 (minimum 1)
  [FAIL] CHK-10 High     OBL-CERTIN-01     Log retention >= 180 days
         logging.retention_days = 90 (minimum 180)
  [FAIL] CHK-11 High     OBL-62443-CRYPTO  TLS minimum version 1.2+
         tls.min_version = 'TLSv1.0' (allowed ['TLSv1.2', 'TLSv1.3'])
  [PASS] CHK-12 Medium   OBL-62443-CRYPTO  Encryption at rest enabled
  [FAIL] CHK-13 Medium   OBL-62443-CRYPTO  Historian backups encrypted
         backup.encrypted = False (expected True)
  [FAIL] CHK-14 Medium   OBL-CERTIN-02     Clock synced to NIC / NPL NTP
         pattern NOT found: ^server\s+
(samay1\.nic\.in|samay2\.nic\.in|time\.nplindia\.org|10\.20\.5\.1\b.*#\s*stratum2-npl)
  [FAIL] CHK-15 High     OBL-FS-03         No expired compensating controls
         expired: CC-001 (expired 2026-06-30)
  [FAIL] CHK-16 Critical OBL-62443-AUTHZ   Modbus write limited to authorised EWS
         prohibited entries: 0.0.0.0/0
  [FAIL] CHK-17 High     OBL-24-RA         Vendor remote access is on-demand
         access_mode = 'always-on' (expected 'on-demand')
  [FAIL] CHK-18 Medium   OBL-24-RA         Vendor sessions are recorded
         session_recording = False (expected True)
  [PASS] CHK-19 High     OBL-24-RA         Vendor access requires MFA
  [FAIL] CHK-20 High     OBL-CERTIN-03     IR plan mandates 6-hour reporting to CERT-In
         pattern NOT found: (within\s+(6|six)\s*(\(6\)\s*)?hours|6-hour)
  [FAIL] CHK-21 Medium   OBL-FS-04         Quarterly self-audit completed within 92 days
         self_audit.last_completed = 2026-04-15 (205 days old, max 92)

[*] PASS=3 FAIL=18 NO_EVIDENCE=0 ERROR=0
[*] Reports: /evidence/reports/gap_20261106T094240Z.json / .md
[*] Portal updated: run #1, CAP opened=18 reopened=0 verified-closed=0
```

Baseline: **3 PASS, 18 FAIL**. The analyzer writes `/evidence/reports/gap_<ID>.json` and `.md`, auto-links each evaluated artifact to its obligation with its hash, and raises one CAP item per failing check.

2 Review results in the portal

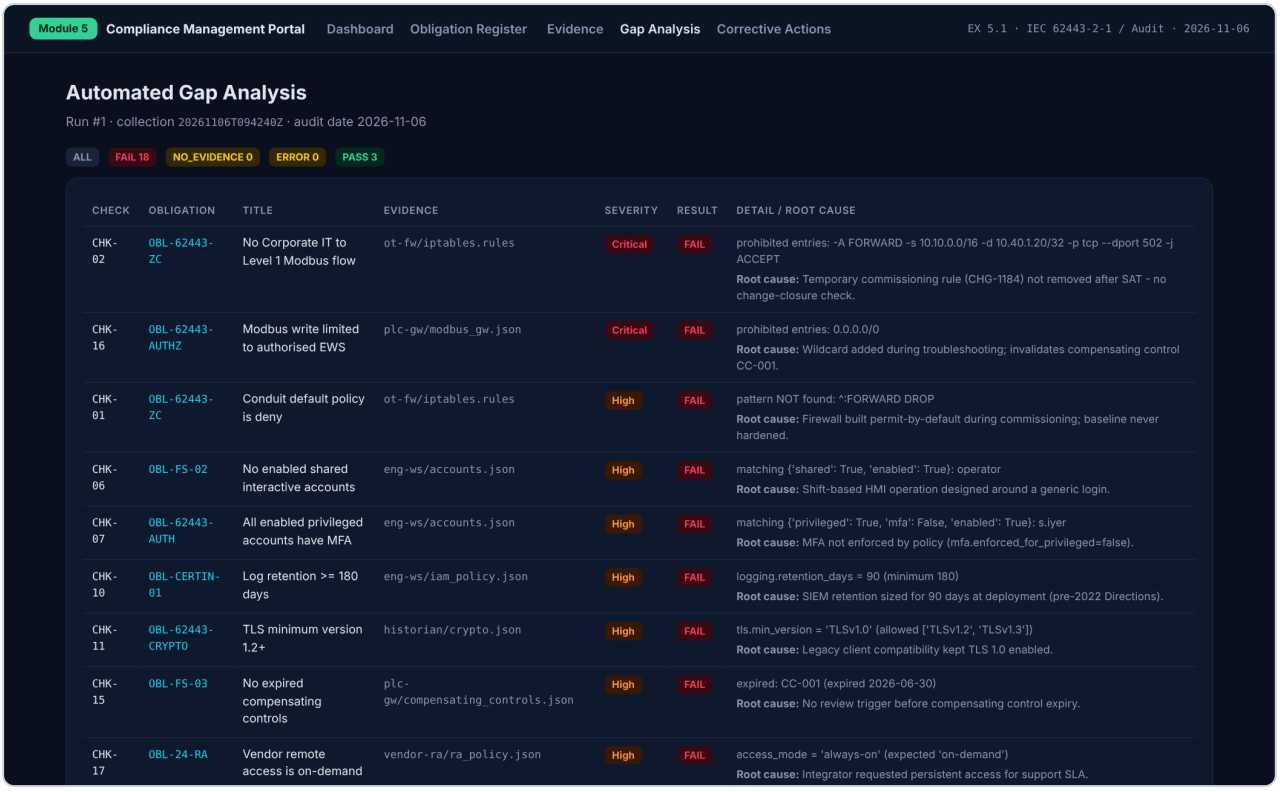


Figure 7.1 — Gap Analysis, run #1: failures sorted by severity with root cause

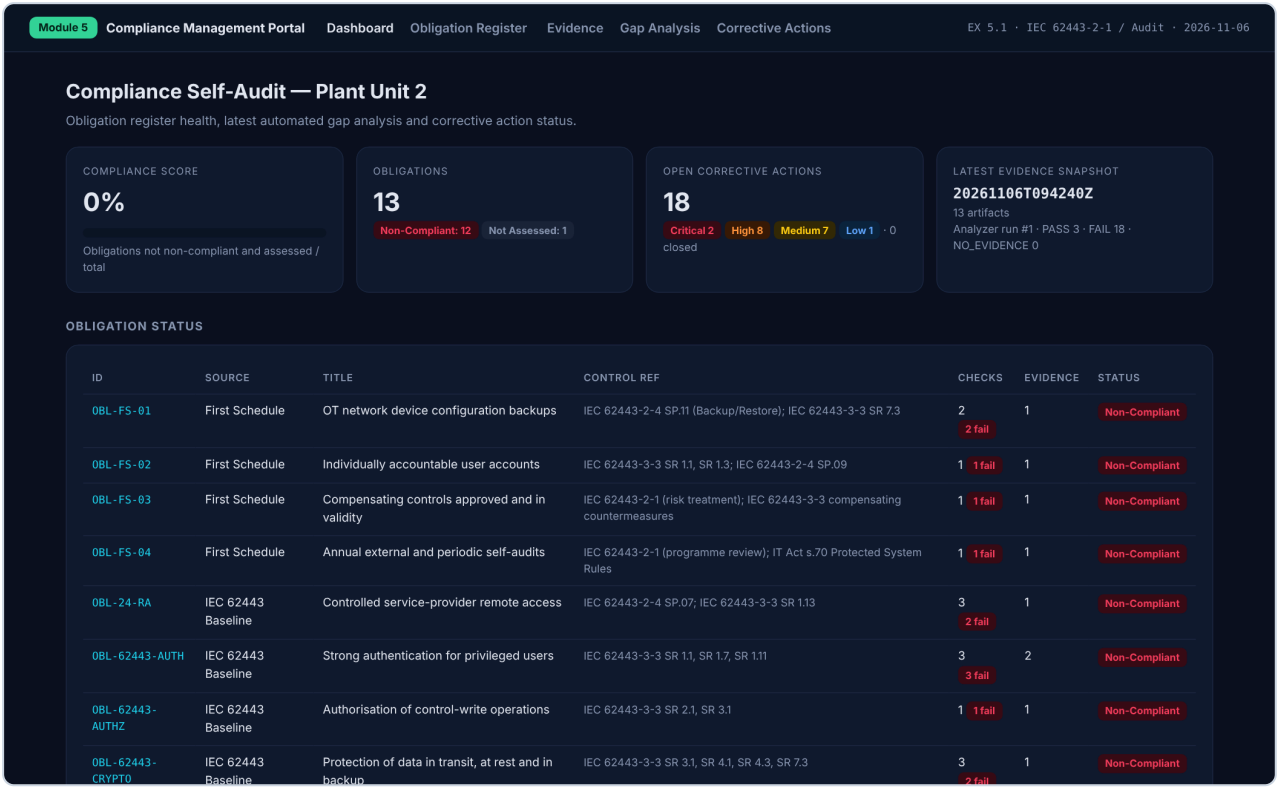


Figure 7.2 — Dashboard after run #1: 11 Non-Compliant, 18 open corrective actions

3 Understand how a verdict is produced

Open `auditor/rules.yaml`. Each check binds one artifact to one obligation through a typed test:

auditor/rules.yaml (excerpt)

```
- id: CHK-02
  obligation: OBL-62443-ZC
  title: No Corporate IT to Level 1 Modbus flow
  asset: ot-fw
  artifact: iptables.rules
  type: regex_absent
  pattern: '^-A FORWARD -s 10\.10\.\S+ .*--dport 502 .*-j ACCEPT'
  severity: Critical
  root_cause: Temporary commissioning rule (CHG-1184) not removed after SAT
  remediation: Remove the rule; add post-SAT rule review to change process.
```

An obligation's status is driven by its **worst** check: OBL-24-RA is Non-Compliant even though CHK-19 (vendor MFA) passes.

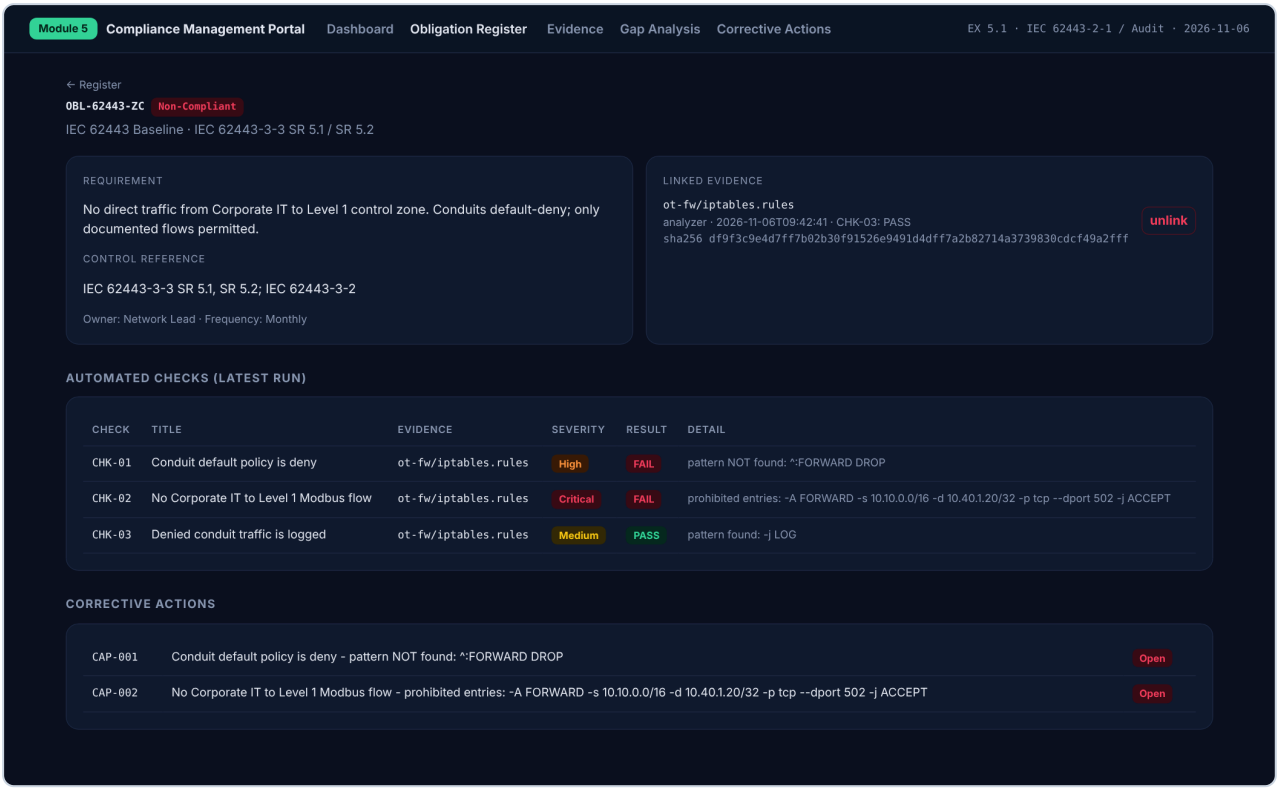


Figure 7.3 — Obligation detail OBL-62443-ZC: linked evidence with hashes, checks and CAP items

4 Validate findings manually (Find → Validate)

Confirm at least three findings against the raw artifact, independent of the script:

auditor

```
root@auditor:/opt/audit# grep -n 'dport 502' /evidence/current/ot-fw/iptables.rules
15:-A FORWARD -s 10.30.1.0/24 -d 10.40.1.0/24 -p tcp --dport 502 -j ACCEPT
17:-A FORWARD -s 10.10.0.0/16 -d 10.40.1.20/32 -p tcp --dport 502 -j ACCEPT   # CHK-02 confirmed

root@auditor:/opt/audit# jq '.write_access.allowed_sources' /evidence/current/plc-gw/modbus_gw.json
[ "10.30.2.15/32", "0.0.0.0/0" ]                                              # CHK-16 confirmed

root@auditor:/opt/audit# jq '.controls[] | {{id,valid_until}}' /evidence/current/plc-
gw/compensating_controls.json
{{ "id": "CC-001", "valid_until": "2026-06-30" }}                             # CHK-15 confirmed
```

5 Find what the scripts miss

Rules only test what someone thought to encode. Trainees must report at least two additional gaps. The full expected set is in Section 9 (M-01..M-09). The most important is in `auth.log`:

eng-ws/auth.log

```
2026-10-30T11:52:19+05:30 EWS-01 winlogon: FAILURE user=s.iyer src=10.10.44.7 reason=bad_password
… 6 failures in 17 seconds from Corporate IT (10.10.0.0/16) …
```

> **This is a security event, not just a compliance gap.** It proves an IT→EWS path exists and that lockout is off. Escalate to the SOC, and ask: has the CERT-In 6-hour reporting clock started?

6 Author a custom rule

Encode one manual finding as a rule, re-run, and confirm it fires:

append to auditor/rules.yaml

```
  - id: CHK-22
    obligation: OBL-62443-CRYPTO
    title: No 3DES / static-RSA cipher suites
    asset: historian
    artifact: crypto.json
    type: regex_absent
    pattern: 'TLS_RSA_WITH_|3DES'
    severity: Medium
    root_cause: Legacy cipher list retained for old OPC clients.
    remediation: Restrict to ECDHE AEAD suites.

root@auditor:/opt/audit# analyze | grep CHK-22
  [FAIL] CHK-22 Medium   OBL-62443-CRYPTO  No 3DES / static-RSA cipher suites
```

PHASE 4

Corrective action, remediation & verification

2:20 – 3:00

Goal: convert findings into owned, dated actions; remediate the most dangerous gaps; prove closure by re-test.

1 Assign owners and dates

Open **Corrective Actions**. Every failing check raised a CAP item with a severity-based due date (Critical 7 days, High 30, Medium 60, Low 90). Refine the action, assign an owner, set status *In Progress* and record the decision context in notes.

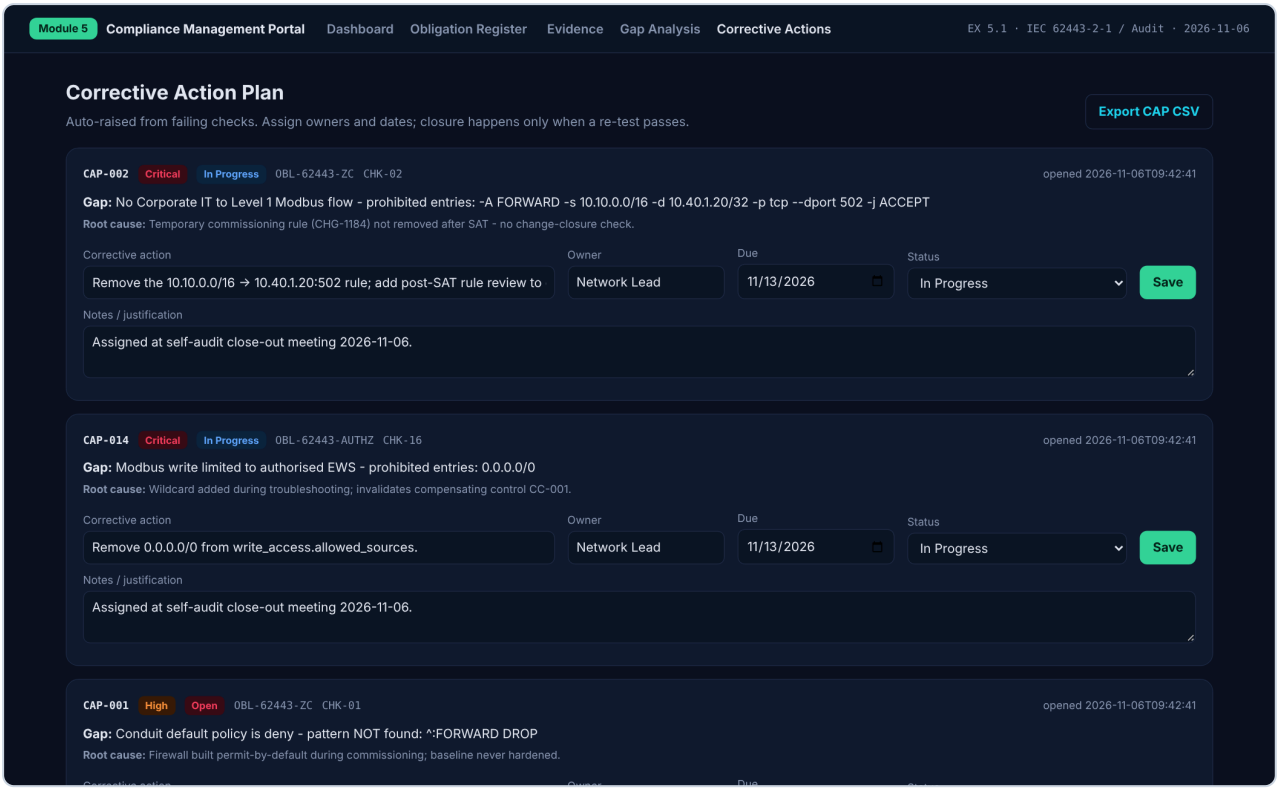


Figure 8.1 — CAP with owners assigned to the Critical and High items

> **Risk Accepted** is permitted only with a written justification, a named risk owner, a compensating control and an expiry date — and note that CC-001 shows what happens when that expiry is not tracked.

2 Remediate (asset owner applies the change)

Edit the files under `range/assets/` on the host. In this walkthrough both Criticals and two further findings were fixed:

```
host

# CHK-02  remove CHG-1184 commissioning rule
$ sed -i '/-s 10\.10\.0\.0\/16/d' range/assets/ot-fw/iptables.rules
# CHK-16  remove Modbus write wildcard
range/assets/plc-gw/modbus_gw.json   "allowed_sources": ["10.30.2.15/32"]
# CHK-07  enrol s.iyer in MFA
range/assets/eng-ws/accounts.json    "username": "s.iyer", ... "mfa": true
# CHK-14  NIC/NPL time source
range/assets/historian/ntp.conf      server time.nplindia.org iburst
```

3 Re-test

```
$ ./lab.sh audit (collect + analyze)

[*] PASS=7 FAIL=14 NO_EVIDENCE=0 ERROR=0
[*] Reports: /evidence/reports/gap_20261106T094244Z.json / .md
[*] Portal updated: run #2, CAP opened=0 reopened=0 verified-closed=4
```

Result: **7 PASS / 14 FAIL**. The portal closes the four CAP items automatically as **Verified-Closed**, stamping the run number and the hash of the evidence that proved the fix.

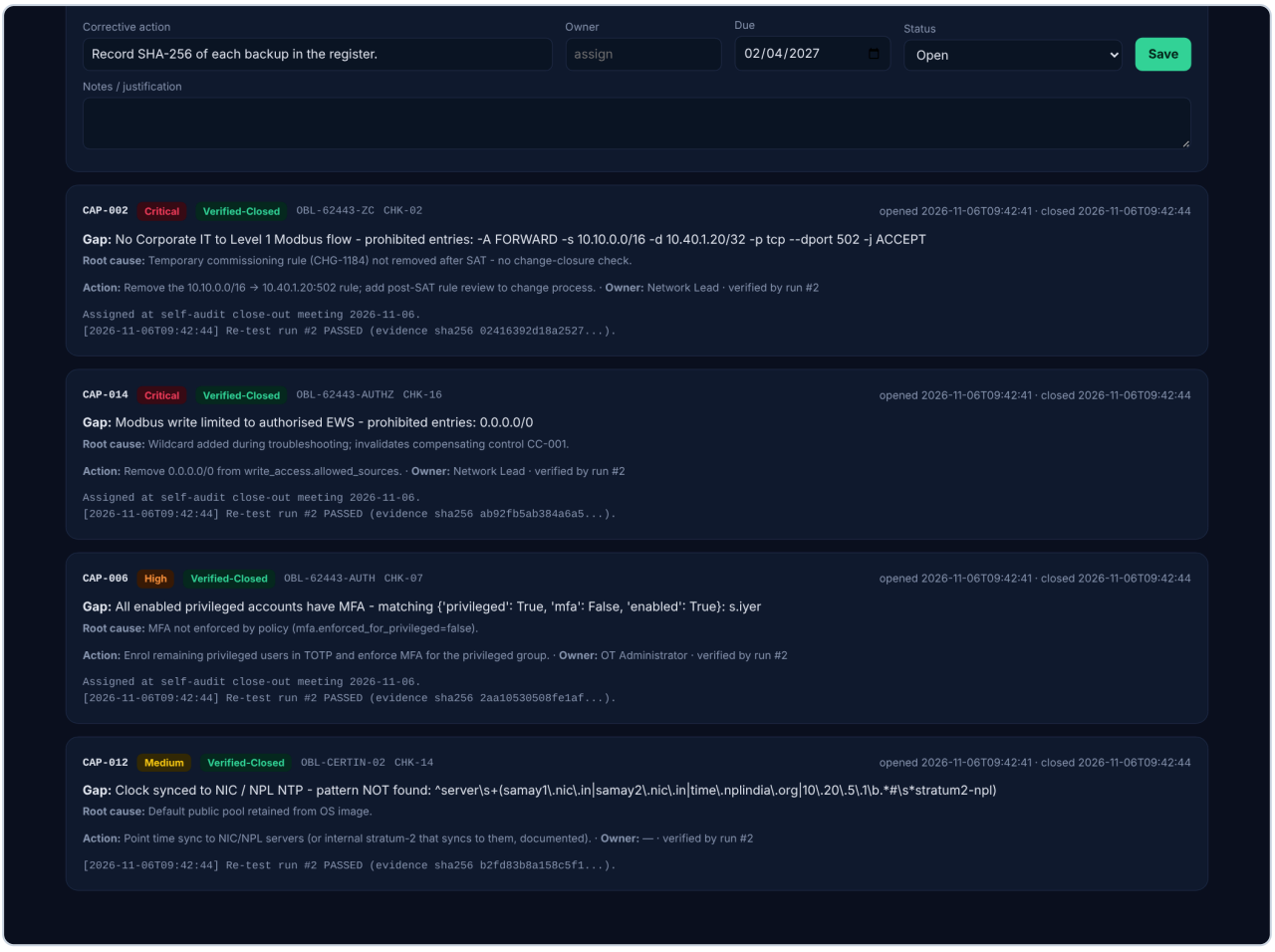


Figure 8.2 — Verified-Closed CAP items with re-test run and evidence hash

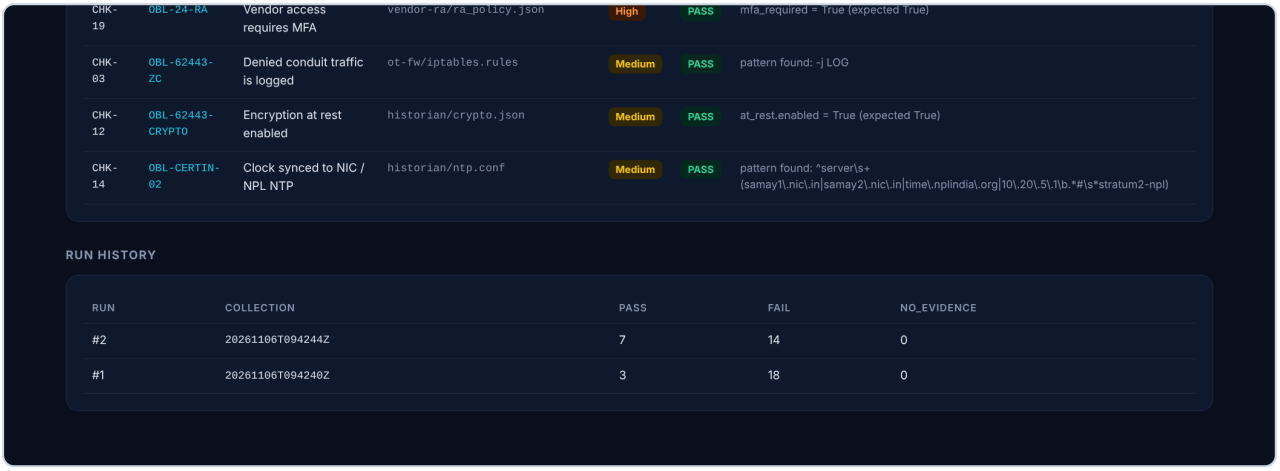


Figure 8.3 — Run history: 18 → 14 failures

4 Closure rules enforced by the portal

- A trainee cannot set *Verified-Closed* manually — only a passing re-test can.
- A Verified-Closed item that fails a later run is **reopened** automatically with a note.
- *Remediated – Pending Verification* is the correct state between fix and re-test.

> **Why:** closure by self-declaration is the root cause of CHG-1184 surviving 18 months. Verification must be evidence-based.

5 Close the self-audit and export D3/D4

Record today as the self-audit completion date in `grc-docs/audit_calendar.json`, re-run, and observe CHK-21 close. Export `cap.csv` (D3) and download the final `/evidence/reports/gap_*.md` plus `custody.log` (D4).

6 Instructor demonstration — full remediation

```
host
$ ./instructor/solve.sh
[*] All fixes applied. Run ./lab.sh audit
$ ./lab.sh audit

[*] PASS=21 FAIL=0 NO_EVIDENCE=0 ERROR=0
[*] Reports: /evidence/reports/gap_20261106T094245Z.json / .md
[*] Portal updated: run #3, CAP opened=0 reopened=0 verified-closed=14
```

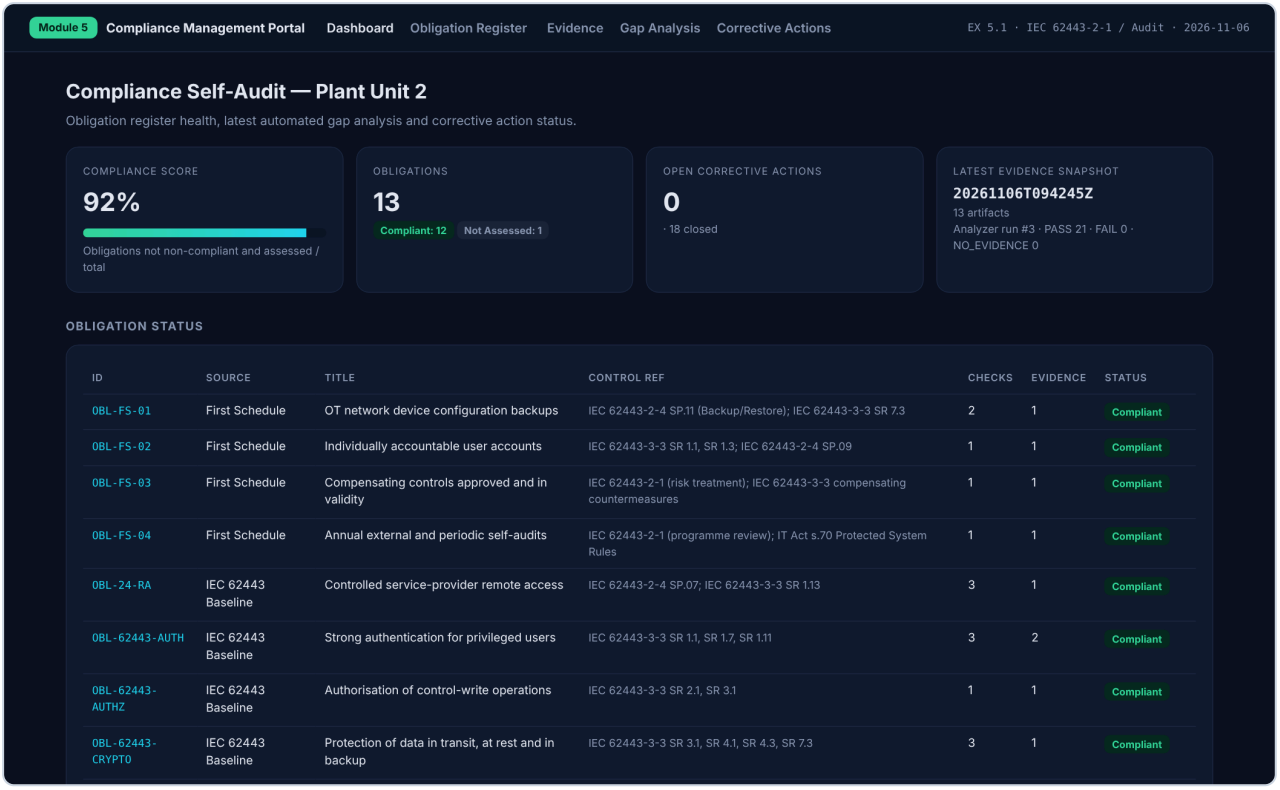


Figure 8.4 — Final state after full remediation: 21/21 checks pass, all CAP items Verified-Closed; OBL-ITA-70 remains Manual Review

> **Note the final dashboard:** OBL-ITA-70 does not become Compliant automatically — documentary obligations require human judgement, and the empanelled-auditor gap (M-08) is still open.

9. Consolidated findings register

9.1 Automated findings (baseline run)

Check	Sev.	Obligation	Finding	Root cause	Corrective action
CHK-02	Critical	OBL-62443-ZC	Corporate IT 10.10.0.0/16 permitted to PLC-01 Modbus/502	Temporary commissioning rule CHG-1184 never removed after SAT	Delete the rule; add post-SAT rule review to change closure
CHK-16	Critical	OBL-62443-AUTHZ	Modbus write (FC 5/6/15/16) allowed from 0.0.0.0/0	Wildcard added during troubleshooting; defeats CC-001	Restrict write sources to EWS 10.30.2.15/32
CHK-01	High	OBL-62443-ZC	FORWARD chain default ACCEPT	Permit-by-default commissioning baseline never hardened	Default DROP; enumerate documented conduit flows
CHK-06	High	OBL-FS-02	Shared enabled account 'operator'	HMI shift model built on a generic login	Named operator accounts; disable 'operator'
CHK-07	High	OBL-62443-AUTH	Privileged s.iyer without MFA	MFA not enforced for privileged group	Enrol TOTP; enforce for privileged group
CHK-10	High	OBL-CERTIN-01	Log retention 90 days (< 180)	SIEM sized pre-2022 Directions	Retain 180 days in-country
CHK-11	High	OBL-62443-CRYPTO	Historian TLS 1.0 permitted	Legacy client compatibility	TLS 1.2 minimum; remove 3DES
CHK-15	High	OBL-FS-03	Compensating control CC-001 expired 2026-06-30	No pre-expiry review trigger	Re-assess and re-approve, or permanent fix; 30-day alert
CHK-17	High	OBL-24-RA	Vendor remote access always-on	Persistent access granted for support SLA	On-demand activation per work order
CHK-20	High	OBL-CERTIN-03	IR plan reports within 24 h (not 6 h)	Plan dated 2024, not aligned with 2022 Directions	Revise IRP-OT-004 §4; re-approve; brief responders
CHK-04	Medium	OBL-FS-01	Firewall config backup 602 days old	Manual, unscheduled backup	Automate monthly export
CHK-08	Medium	OBL-62443-AUTH	Password minimum length 8	Legacy domain defaults	Minimum 12+
CHK-09	Medium	OBL-62443-AUTH	Account lockout disabled	Avoid HMI lock-outs; no risk assessment	Threshold 5–10; kiosk via CC
CHK-13	Medium	OBL-62443-CRYPTO	Historian backups unencrypted	Backup job lacks key	AES-256 backup encryption
CHK-14	Medium	OBL-CERTIN-02	NTP uses pool.ntp.org	Default OS image config	NIC / NPL time sources

CHK-18	Medium	OBL-24-RA	Vendor sessions not recorded	Licence not procured	Enable recording; retain with SIEM
CHK-21	Medium	OBL-FS-04	Self-audit 205 days old (quarterly)	No owner/schedule	Complete Ex 5.1; record date
CHK-05	Low	OBL-FS-01	Backup integrity hash not recorded	Procedure lacks hashing	Record SHA-256 per backup

Passing at baseline: CHK-03 (deny logging), CHK-12 (encryption at rest), CHK-19 (vendor MFA).

9.2 Manual findings — beyond the scripts

ID	Finding	Evidence and significance
M-01	**Shared account in active use**	`auth.log` : `operator` logs on from HMI-01, HMI-02 and HMI-03 on one day — operator actions are non-attributable. Corroborates CHK-06 with behavioural evidence.
M-02	**Brute force from corporate IT**	Six failed `s.iyer` logons in 17 s from **10.10.44.7** (Corporate IT) to EWS-01. Proves an IT→EWS path exists *and* that lockout is absent. Should be triaged as a potential incident — the CERT-In 6-hour clock question.
M-03	**Weak cipher suite**	`TLS_RSA_WITH_3DES_EDE_CBC_SHA` remains enabled (Sweet32; no forward secrecy) — persists even after TLS 1.2 is enforced.
M-04	**Dormant privileged vendor account**	`vendor_ctrl` is privileged, last used 2026-09-02, and reachable over always-on remote access into L1/L2.
M-05	**CC-001 invalid before it expired**	CC-001's control (“Modbus write only from EWS”) is defeated by the `0.0.0.0/0` write source (CHK-16). The control never operated as approved.
M-06	**IR plan review cycle**	IRP-OT-004 is reviewed every two years and predates the 2022 Directions; no evidence of a 6-hour reporting drill.
M-07	**Backup concentration**	Firewall and historian backups share `nas01` ; firewall backup is unhashed and historian backup unencrypted — single point of failure.
M-08	**s.70 evidence gap**	ISMS policy *claims* an annual empanelled audit, but the audit calendar shows auditor “TBD” with the audit due 2026-11-20. Status must stay Manual Review, not Compliant.
M-09	**Internal NTP source**	`10.20.5.1 prefer` is acceptable only if documented as traceable to NIC/NPL.

10. Deliverables & assessment rubric

ID	Deliverable	Where it comes from
D1	Obligation register (13+ obligations)	Portal → Obligation Register → Export CSV
D2	Evidence traceability matrix with assessment notes	Portal → Evidence → Export links CSV
D3	Corrective Action Plan with owners, dates and verification state	Portal → Corrective Actions → Export CAP CSV
D4	Final gap report and chain-of-custody log	Repository :8081 → `/reports/gap_*.md`, `/custody.log`

Assessment rubric (100 marks)

Criterion	Marks	Distinction-level evidence
Missing obligations registered; requirements testable; controls mapped	20	All three added with exact IDs; weak seeded wording improved
Documentary evidence linked with meaningful notes	15	Notes state what is proved and what is not (s.70 claim vs calendar)
Findings validated; ≥ 2 gaps beyond scripts	20	Identifies the IT-sourced brute force and escalates it as a potential incident
Custom rule written and firing	10	Rule has root cause and remediation, not just a pattern
CAP quality	15	Owners, realistic dates relative to 20 Nov audit, justified risk acceptance only
Remediation verified by re-test	20	Both Criticals + ≥ 2 others Verified-Closed; links CHK-16 to CC-001 validity

11. Debrief & discussion

1. **Closure by re-test.** Why does the portal refuse manual Verified-Closed? Relate this to CHG-1184.
2. **Aggregate status.** CHK-19 passes, so is OBL-24-RA compliant? What does “worst check wins” say about reporting compliance upward?
3. **Compensating controls.** CC-001 was approved but never operated. How would you test the *operating effectiveness* of a compensating control, not just its approval?
4. **Audit vs incident.** When the auditor finds evidence of an attack (M-02), who must be told, and when does the 6-hour CERT-In clock start — at audit discovery or at “noticing”?
5. **Risk acceptance in OT.** When is accepting a risk defensible on a safety-relevant system? Who signs, and what must accompany it?
6. **Automation limits.** Which obligations in this register can never be fully automated, and why?
7. **Supply chain link (Module 5).** Three root causes trace to the integrator: CHG-1184, persistent vendor access, unpatched PLC firmware. How would IEC 62443-2-4 supplier requirements and FAT/SAT cyber test criteria have prevented each? (Bridges to Exercises 5.2–5.3.)

Key takeaways

REGISTER
An obligation not in the register has no owner and is never tested.

EVIDENCE
Hash at collection, record custody, annotate every link.

ANALYSIS
Automate the repeatable, then hunt for what automation misses.

CLOSURE
A finding is closed when re-test evidence says so — not when someone says so.

12. Troubleshooting

Symptom	Cause and fix
Port 8080 / 8081 already in use	Change the host port in `docker-compose.yml` (e.g. `"9080:8080"`) and set `REPO_URL` accordingly.
`collect` shows UNREACHABLE	Asset container down or `range/assets/<asset>` missing. Run `./lab.sh status`; if the folder is empty, `./lab.sh reset` then `up`.
Analyzer: “No evidence snapshot”	Run `collect` before `analyze`, or use `audit`.
Portal shows old results after a fix	The portal reflects the last analyzer run. Re-run `./lab.sh audit`; editing files alone changes nothing.
CHK-xx shows ERROR	A remediation broke JSON syntax. Validate with `jq . file.json` in the auditor shell.
Date-based results differ between batches	Checks use today's date. Pin `AUDIT_DATE: "2026-11-06"` under the auditor service for reproducible marking.
Start the next batch	`./lab.sh reset` wipes evidence, portal DB and all remediations.

Appendix A — Command reference

Command	Effect
`./lab.sh up`	Build and start; seed `range/assets` on first run
`./lab.sh collect | analyze | audit`	Evidence collection, gap analysis, or both
`./lab.sh shell`	Auditor shell (bridges IT and OT)
`./lab.sh status | logs [svc] | down`	Operate the stack
`./lab.sh reset`	Restore the vulnerable baseline
`./instructor/solve.sh`	Apply every planted fix (instructor demo)
`GET /api/status · /export/{register,evidence,cap}.csv`	Portal API and exports

Appendix B — Rule engine reference

Type	Parameters	Passes when
`regex_present`	pattern	pattern matches (multiline) in the artifact
`regex_absent`	pattern	no match; failures list the offending lines
`json_equals`	path, value	value at dotted path equals expected
`json_min`	path, value	numeric value ≥ minimum
`json_in`	path, values	value is in the allowed list
`json_none_match`	path, where, report_field	no list element matches all `where` fields
`json_none_expired`	path, field, report_field	no list element's date field is before the audit date
`date_within_days`	path, days	date is no older than *days* before the audit date

Disclaimer. Regulatory clause wording in this lab is a training paraphrase. Verify against the authoritative CERT-In Directions, Protected System Rules and licensed IEC 62443 texts before reuse in a real engagement. All plant data is fictitious.